

SECTION 1: PURPOSE AND SCOPE

This policy establishes the requirements for identifying, assessing, and managing risks associated with third-party vendors, suppliers, contractors, and service providers that have access to ACME Corporation systems, data, or facilities, or whose products or services are incorporated into ACME's operations. All business units that engage third parties are subject to this policy.

SECTION 2: VENDOR CLASSIFICATION

Vendors must be classified into one of three risk tiers based on the sensitivity of data they access and the criticality of the services they provide.

Tier 1 (Critical Vendors): Vendors that process Restricted data, provide critical infrastructure services, or have administrative access to ACME systems. Examples include cloud infrastructure providers, payroll processors, and managed security service providers. Tier 1 vendors require the most rigorous due diligence and are reviewed annually.

Tier 2 (High-Risk Vendors): Vendors that process Confidential data or provide services that, if disrupted, would materially impact ACME operations. Examples include CRM platforms, HR software providers, and marketing analytics tools. Tier 2 vendors are reviewed every 18 months.

Tier 3 (Standard Vendors): Vendors that access only Internal or Public data and provide non-critical services. Examples include office supply vendors, event management firms, and business travel agencies. Tier 3 vendors complete a self-assessment questionnaire and are reviewed every 3 years.

SECTION 3: VENDOR ONBOARDING AND DUE DILIGENCE

No vendor may be onboarded or granted access to ACME systems or data until the applicable due diligence process has been completed and approved. The Procurement team is responsible for initiating the vendor onboarding workflow via the Vendor Portal.

Tier 1 vendor due diligence must include: a completed Third-Party Risk Assessment questionnaire; review of SOC 2 Type II report (not older than 12 months) or equivalent; review of the vendor's information security policy and incident response plan; a penetration testing summary from the past 12 months; financial stability check; sanctions screening against OFAC and applicable international sanctions lists; a signed Data Processing Agreement (DPA) and Master Service Agreement (MSA); and CISO approval before access is granted.

Tier 2 vendor due diligence must include: a completed Third-Party Risk Assessment questionnaire; review of SOC 2 Type I or II report or equivalent; a signed DPA; and IT Security team approval.

Tier 3 vendor due diligence must include: completion of the ACME Vendor Self-Assessment form and a signed vendor agreement with standard security and confidentiality clauses.

SECTION 4: CONTRACTUAL REQUIREMENTS

All contracts with Tier 1 and Tier 2 vendors must include the following provisions: compliance with ACME's security requirements; the right to audit the vendor's security controls with reasonable notice; mandatory incident notification to ACME within 24 hours of any security incident that may affect ACME data; data breach notification timelines

consistent with applicable law; data deletion or return upon contract termination; restriction on subcontracting to fourth parties without ACME's prior written consent; and compliance with applicable data protection laws (GDPR, CCPA, etc.).

Contracts must not be executed, renewed, or modified without review and sign-off from Legal and, for Tier 1 vendors, the CISO.

SECTION 5: ONGOING MONITORING

Tier 1 vendors must undergo a formal annual review that reassesses their risk profile, reviews updated SOC 2 reports, and evaluates any security incidents that occurred during the year. Significant changes to a Tier 1 vendor's ownership, infrastructure, or security posture must be reported to ACME immediately and trigger an out-of-cycle review.

Continuous monitoring of Tier 1 vendors must be performed using an approved vendor risk intelligence platform (e.g., BitSight, SecurityScorecard). Significant score drops or newly identified vulnerabilities in the vendor's publicly observable infrastructure must be escalated to the IT Security team within 48 hours for review.

All vendors must be re-screened against sanctions lists at contract renewal and whenever the IT Security team issues a mandatory re-screen notice.

SECTION 6: VENDOR OFFBOARDING

When a vendor relationship ends, the following must be completed within 10 business days: revocation of all access credentials and API keys; confirmation that all ACME data held by the vendor has been deleted or returned (with written certification from the vendor); retrieval or verified destruction of any ACME-owned hardware in the vendor's possession; closure of the vendor record in the Vendor Portal; and retention of contract and due-diligence records for 7 years after the end of the relationship.

If a vendor terminates the relationship unexpectedly or becomes insolvent, the IT Security team must be notified immediately to initiate emergency access revocation.

SECTION 7: FOURTH-PARTY RISK

Tier 1 vendors must disclose all subcontractors (fourth parties) that have access to ACME data. Fourth parties are subject to the same minimum security requirements as the vendor itself. Vendors must obtain ACME's written approval before adding new fourth parties with access to ACME data. ACME reserves the right to require replacement of any fourth party that fails to meet the applicable security standards.

SECTION 8: COMPLIANCE AND ENFORCEMENT

Non-compliance with this policy, including engaging a vendor without completing the required due diligence, is a policy violation that must be reported to the CISO.

Violations may result in disciplinary action, contract suspension, or contract termination. Vendor risk management compliance is audited semi-annually by the Information Security team and reported to the Board Audit Committee annually.